

As-tu le droit d'utiliser cette donnée ? QCM /20



Avant de manipuler un vrai dataset. Durée conseillée : 20 min · 4 paliers · corrigé détaillé.

Objectif : repérer tes réflexes face aux données personnelles (accès, minimisation, anonymisation, conservation, partage) avant qu'une erreur de manipulation devienne un problème. Sur mon premier vrai dataset en entreprise, personne ne m'avait expliqué où s'arrêtait le bon sens : je l'ai appris colonne par colonne.

Document pédagogique : il reste au niveau du principe et du réflexe professionnel, ne remplace pas un avis juridique et ne garantit aucune conformité.

Repères : 12/20 = premiers réflexes en place, 16/20 = vigilance solide sur un dataset réel.

Candidat _____ Date _____ Note _____ /20

Palier A : comprendre ce qu'est une donnée personnelle.

Cinq questions pour poser le vocabulaire de base avant les cas pratiques.

Question 1. Qu'est-ce qu'une donnée personnelle, au sens le plus large ?

- a) Une donnée qui contient explicitement un nom et un prénom.
- b) Une information qui permet d'identifier une personne, directement ou en la croisant avec d'autres informations.
- c) Une donnée stockée dans une base de production, par opposition à un fichier de test.
- d) Une donnée chiffrée, donc automatiquement protégée.

Question 2. Tu récupères les logs serveur d'une appli web pour analyser le trafic. L'adresse IP des visiteurs :

- a) N'est jamais une donnée personnelle : une IP identifie une machine, jamais une personne.
- b) N'est pas une donnée personnelle, car elle change à chaque connexion.
- c) Est une donnée personnelle uniquement si elle est fixe.
- d) Peut potentiellement être une donnée personnelle : croisée avec d'autres informations (fournisseur d'accès, horodatage), elle peut permettre une identification indirecte.

Question 3. Un dataset RH remplace les noms par un identifiant du type EMP482, la table de correspondance existant ailleurs dans l'entreprise. Cette donnée pseudonymisée :

- a) Reste une donnée personnelle tant qu'une clé de correspondance permet de retrouver l'identité.
- b) Devient anonyme dès qu'un identifiant remplace un nom.
- c) N'est plus concernée par aucune précaution, seul le nom comptait.
- d) Est une donnée personnelle uniquement si l'identifiant est numérique.

Question 4. On te demande de constituer un fichier client « au cas où on en aurait besoin plus tard ». Pourquoi ce motif pose problème ?

- a) Il ne pose pas de problème si le fichier reste en interne.
- b) C'est une bonne pratique, mais optionnelle si l'équipe est petite.
- c) Un traitement de données doit être rattaché à un objectif précis ; « au cas où » n'est pas une finalité.
- d) La finalité ne concerne que les données envoyées à des clients externes.

Question 5. Un dataset RH contient une colonne « religion » et une colonne « état de santé déclaré », en plus des données classiques. Que change ce type de donnée ?

- a) Rien, ce sont des colonnes comme les autres.
- b) Ces catégories de données appellent une vigilance renforcée par rapport à une donnée ordinaire.
- c) Seule la colonne santé est concernée, la religion reste neutre.
- d) Cela ne concerne que le service RH, pas les analystes qui manipulent le fichier.

Palier B : droits d'accès et minimisation au quotidien.

Cinq questions qui font basculer le savoir vers le réflexe terrain.

Question 6. Un client écrit au support pour savoir quelles données l'entreprise détient sur lui. Ta première hypothèse de travail :

- a) Une personne concernée dispose en principe d'un droit de regard sur les données détenues à son sujet.
- b) Ces informations restent internes à l'entreprise, il n'a pas à les connaître.
- c) Il y a droit uniquement s'il est encore client actif.
- d) Il n'y a pas de droit, sauf loi spécifique au secteur.

Question 7. Pour un formulaire d'inscription à une newsletter, un collègue propose d'ajouter date de naissance, profession et situation familiale, « on ne sait jamais, ça pourra servir ». Le bon réflexe :

- a) Accepter : plus on a de données, mieux on segmente plus tard.
- b) Accepter tant que les champs restent facultatifs.
- c) Accepter si le formulaire précise « optionnel ».
- d) Rappeler que le principe de minimisation invite à ne collecter que ce qui sert la finalité déclarée, pas à collecter large au cas où.

Question 8. La table « salaires » est accessible sans restriction à toute l'équipe analytics, alors que seule la RH en a besoin pour ses analyses. Ce que ça révèle :

- a) Rien d'anormal, l'équipe analytics doit avoir accès à toutes les tables pour être efficace.
- b) Un accès à une donnée sensible comme le salaire devrait être restreint aux personnes qui en ont réellement besoin.
- c) Le problème ne se pose que si les données sortent de l'entreprise.
- d) Cela ne concerne pas l'équipe analytics, seulement les développeurs.

Question 9. Tu reçois un dataset marketing pour un score de propension à l'achat. Il contient une colonne « religion » sans lien apparent avec la finalité déclarée. Le bon réflexe :

- a) Rien à signaler, plus de colonnes veut dire un meilleur modèle.
- b) Il suffit de ne pas l'utiliser dans le modèle, la garder dans le fichier ne pose pas de problème.
- c) Repérer qu'une colonne sans lien avec la finalité déclarée est un signal de collecte disproportionnée, à faire remonter.
- d) Le problème ne concerne que les colonnes contenant un nom.

Question 10. Un collègue d'une autre équipe te demande un extract complet de la base clients, « au cas où, pour un projet pas encore défini ». Tu :

- a) Envoies l'extract : un collègue en interne n'est jamais un risque.
- b) Questionnes la finalité avant d'envoyer, même pour une demande en interne.
- c) Envoies l'extract, mais retires uniquement les noms.
- d) Refuses systématiquement toute demande venant d'une autre équipe.

Palier C : anonymisation, pseudonymisation, conservation.

Cinq questions qui montent en technicité côté manipulation du dataset. Sur le terrain, c'est souvent ici que la confusion s'installe.

Question 11. Quelle est la vraie différence entre anonymisation et pseudonymisation ?

- a) Ce sont deux mots pour la même opération technique.
- b) La pseudonymisation supprime toute possibilité de ré-identification, l'anonymisation non.
- c) L'anonymisation concerne les noms, la pseudonymisation les adresses email.
- d) L'anonymisation vise une ré-identification rendue impossible, la pseudonymisation conserve une clé de correspondance qui permet de revenir à l'identité.

Question 12. Pour une analyse ponctuelle de churn, tu t'apprêtes à exporter le fichier client avec noms, prénoms et emails. Avant de lancer l'export :

- a) Tu vérifies si l'analyse a réellement besoin des identités ou si un identifiant technique suffirait.
- b) Tu exportes tel quel : un export nominatif garantit toujours la traçabilité de l'analyse.
- c) Tu changes uniquement le format du fichier (CSV plutôt qu'Excel).
- d) Tu ne te poses la question que si l'export est récurrent.

Question 13. Un dataset RH contient encore les dossiers complets d'employés partis il y a plus de dix ans, sans qu'aucune analyse ne les utilise. Ta lecture :

- a) C'est normal, plus l'historique est long, plus les statistiques RH sont fiables.
- b) Le problème ne se pose que si les données sont diffusées hors de l'entreprise.
- c) Tant que le stockage ne coûte rien, la durée de conservation n'a pas d'importance.
- d) Une donnée n'a en principe pas vocation à être conservée indéfiniment; la durée doit rester liée à la finalité.

Question 14. Tu découvres une table d'emails clients jamais purgée depuis dix ans, y compris pour des comptes clos. Le bon réflexe :

- a) Considérer que c'est une situation neutre tant que la table n'est pas utilisée activement.
- b) Repérer que ce signal de conservation excessive mérite d'être remonté, pas ignoré.
- c) Estimer que le problème ne concerne que les données bancaires, pas les emails.
- d) Renommer la table pour que le signal disparaisse.

Question 15. Pour « anonymiser » un fichier avant de le partager, un collègue retire uniquement la colonne nom et garde code postal, date de naissance et genre. Ton évaluation :

- a) Supprimer uniquement le nom ne suffit pas toujours : le croisement de code postal, date de naissance et genre peut permettre une ré-identification.
- b) C'est suffisant : sans nom, une personne ne peut plus être identifiée.
- c) Le risque disparaît si le fichier reste en interne.
- d) Le genre et la date de naissance ne sont jamais des données identifiantes.

Palier D : cas terrain, partage, export, doute.

Cinq questions, les plus proches du quotidien réel. C'est le palier où se joue la vigilance qui reste après le test.

Question 16. Un manager te demande un export nominatif des performances individuelles de l'équipe, pour illustrer un post LinkedIn de fin d'année. Le bon réflexe :

- a) Exécuter la demande : un manager est habilité à demander ce qu'il veut.
- b) Refuser systématiquement toute demande d'un manager sur des données individuelles.
- c) Questionner la demande avant exécution, même venant d'un manager.
- d) Anonymiser les noms, mais garder les chiffres individuels visibles.

Question 17. Un stagiaire rejoint l'équipe analytics et reçoit automatiquement un accès complet au dashboard clients, sans restriction, « puisqu'il fait partie de l'équipe ». Ton analyse :

- a) C'est normal : appartenir à l'équipe donne le droit d'accéder à toutes les données de l'équipe.
- b) L'appartenance à une équipe ne justifie pas à elle seule un accès non restreint à des données clients.
- c) Le problème ne se pose que si le stagiaire exporte les données.
- d) Un accès temporaire n'a pas besoin d'être encadré.

Question 18. L'environnement de test de l'équipe technique utilise une copie complète et non modifiée de la base clients de production. Ton diagnostic :

- a) C'est la meilleure pratique : tester avec de vraies données garantit un résultat fiable.
- b) Le problème ne concerne que la base de production, pas les copies de test.
- c) C'est acceptable tant que l'environnement de test n'est pas accessible depuis l'extérieur.
- d) Un environnement de test devrait utiliser des données fictives ou anonymisées plutôt que de vraies données clients.

Question 19. Un client t'écrit directement, en tant qu'analyste, pour demander la liste des données que l'entreprise détient sur lui. Tu :

- a) Réponds toi-même directement avec un export de la base.
- b) Ignore la demande, ce n'est pas ton rôle.
- c) Prends la demande au sérieux et la remotes selon le processus interne, sans trancher seul.
- d) Demandes au client de reformuler sa demande par écrit avant d'agir.

Question 20. Tu as un doute sur la conformité d'un traitement de données que tu es en train de construire. Le réflexe le plus transférable :

- a) Solliciter la personne ou l'instance responsable en interne (par exemple un DPO), plutôt que de trancher seul.
- b) Continuer : le doute n'est jamais un motif suffisant pour interrompre un projet.
- c) Arrêter définitivement le projet sans en parler à personne.
- d) Appliquer la solution la plus stricte possible, sans vérifier si elle est adaptée.

Corrigé et explications.

Un point par bonne réponse. Compte ton score, puis relis surtout les explications des questions où tu as hésité.

- 1. **b)** Une donnée personnelle est une information qui permet d'identifier quelqu'un, directement ou en la croisant avec d'autres informations. L'erreur classique est de croire que seul un nom identifie une personne.
- 2. **d)** Une IP peut être une donnée personnelle : croisée avec d'autres informations, elle peut permettre une identification indirecte. L'erreur classique est de traiter une donnée « technique » comme automatiquement neutre.
- 3. **a)** Tant qu'une clé de correspondance permet de retrouver l'identité, une donnée pseudonymisée reste une donnée personnelle. L'erreur classique est de confondre pseudonymisation et anonymisation.
- 4. **c)** Un traitement doit être rattaché à un objectif précis ; « au cas où » n'est pas une finalité. L'erreur classique est de traiter la finalité comme une formalité optionnelle plutôt qu'un principe de base.
- 5. **b)** Origine, santé, opinions sont des catégories qui appellent une vigilance renforcée. L'erreur classique est de traiter toutes les colonnes d'un dataset RH de la même façon, sans distinguer leur sensibilité.
- 6. **a)** Une personne concernée dispose en principe d'un droit de regard sur les données détenues à son sujet. L'erreur classique est de croire que ces données restent la propriété exclusive de l'entreprise.
- 7. **d)** Le principe de minimisation invite à ne collecter que ce qui sert la finalité, pas à empiler des champs au cas où. L'erreur classique est de confondre minimisation et austérité, alors qu'il s'agit de coller à l'usage réel.
- 8. **b)** Un accès à une donnée sensible comme le salaire devrait rester restreint aux personnes qui en ont réellement besoin. L'erreur classique est de confondre appartenance à une équipe et besoin réel d'accès.
- 9. **c)** Une colonne sans lien avec la finalité déclarée est un signal de collecte disproportionnée, même si elle n'est jamais utilisée dans le modèle. L'erreur classique est de croire qu'une colonne inutilisée est une colonne neutre.
- 10. **b)** Une demande « au cas où », même interne, mérite d'être questionnée avant d'être satisfaite. L'erreur classique est de penser qu'un collègue en interne ne représente jamais un risque.

- 11. d)** L'anonymisation vise une ré-identification rendue impossible, la pseudonymisation conserve une clé de correspondance. L'erreur classique est d'utiliser les deux mots comme synonymes.
- 12. a)** Avant un export nominatif, il est prudent de vérifier si l'usage prévu nécessite réellement les identités. L'erreur classique est d'exporter par réflexe le fichier complet plutôt que le sous-ensemble utile.
- 13. d)** Une donnée n'a en principe pas vocation à être conservée indéfiniment, la durée doit rester liée à la finalité. L'erreur classique est de laisser un historique s'accumuler faute de date de péremption définie.
- 14. b)** Un jeu de données jamais purgé sur une longue période est un signal à faire remonter, pas une situation neutre. L'erreur classique est d'attendre qu'un incident survienne avant de s'interroger sur la conservation.
- 15. a)** Retirer uniquement le nom ne suffit pas toujours : croiser code postal, date de naissance et genre peut suffire à ré-identifier quelqu'un. L'erreur classique est de réduire l'anonymisation à la seule suppression du nom.
- 16. c)** Une demande hiérarchique d'export nominatif mérite d'être questionnée avant exécution. L'erreur classique est de confondre autorité hiérarchique et légitimité automatique de la demande.
- 17. b)** L'appartenance à une équipe ne justifie pas à elle seule un accès non restreint. L'erreur classique est de calquer les droits d'accès sur l'organigramme plutôt que sur le besoin réel.
- 18. d)** Un environnement de test devrait utiliser des données fictives ou anonymisées. L'erreur classique est de penser qu'un environnement « interne » ou « de test » échappe aux mêmes précautions que la production.
- 19. c)** Une demande d'un client sur ses propres données doit être prise au sérieux et remontée selon le processus interne. L'erreur classique est de répondre seul, dans l'urgence, sans passer par le circuit prévu.
- 20. a)** Face à un doute, le bon réflexe est de solliciter la personne ou l'instance responsable en interne, pas de trancher seul. L'erreur classique est de préférer l'inaction silencieuse ou une décision solitaire à la question posée à qui de droit.

À retenir : en cas de doute sur une donnée, le réflexe n'est jamais de trancher seul. Ce document reste pédagogique et de portée générale; il ne remplace pas un avis juridique et ne garantit aucune conformité.

Fait main, en solo.

Si ce test t'a aidé à poser les bons réflexes, partage-le autour de toi : il peut éviter une erreur à un autre analyste. Et si un point mérite d'être creusé avec un vrai juriste, c'est exactement le réflexe attendu.

Dylan

